



Arbeidskrav 2

Emne 2 – vår 2026

Table of Contents



Arbeidskrav 2

Emne 2 – vår 2026

		1
AI-ERKLÆRING		3
DEL 1- INNLEDNING		4
1. TRUSSELIDENTIFISERING OG ANGREPSVEKTORER		4
<i>Phishing</i>		5
<i>Brute-Force (Credential stuffing)</i>		5
<i>Skadevare</i>		6
<i>Kommunikasjon</i>		6
<i>Hvordan henger disse punktene sammen?</i>		7
2.2 NETTVERKSARKITEKTUR OG SEGMENTERING.....		7
<i>Svakheter</i>		10
<i>Forbedringer</i>		10
2.3 HENDELSESANALYSE OG PRIORITERING		11
<i>Redusering av risiko</i>		12
2.4 SIKKERHETSTILTAK		13
<i>MFA</i>		13
<i>E-post sikkerhet</i>		14
<i>EDR</i>		14
<i>DNS-filtrering</i>		14
<i>Segmentering av nettverket</i>		15
<i>Tilgangskontroll</i>		15
<i>IDS / IPS</i>		15
<i>Opplæring</i>		16
2.5 OVERVÅKING, DETEKSJON OG HENDELSESHÅNDTERING.....		16
<i>Umiddelbare tiltak</i>		19
<i>Roller</i>		20
DEL 2 - TEKNISK UNDERSØKELSESMETODE: PAKKEANALYSE MED WIRE SHARK		21
BEGRENSNINGER		23

AI-erklæring

Sjekklisten nedenfor er fylt ut:

- Har deler av teksten blitt kontrollert med verktøy som Grammarly, Ginger, LanguageTool eller lignende? **Nei**
- Har deler av teksten blitt generert ved hjelp av verktøy som ChatGPT, osv.? **Nei**
- Skrivehjelp: Har noen ideer eller tilnærminger i rapporten blitt foreslått av verktøy som ChatGPT, Google Bard eller lignende? **Ja**
- Bildegenerering: Har noen bilder/figurer i rapporten blitt generert ved hjelp av verktøy som Midjourney, DALL-E eller lignende? **Nei**
- Andre KI-verktøy: Har du brukt andre KI-verktøy? **Nei**

Har du brukt KI-baserte verktøy eller ressurser i arbeidet med denne rapporten?

Ja. Jeg har brukt ChatGPT som støtteverktøy i arbeidet med rapporten.

1. Tekstgenerering

Jeg har skrevet innholdet og de faglige vurderingene selv. ChatGPT er brukt som støtte for å gjøre enkelte setninger tydeligere og komme med enkle eksempler i begrunnelsene mine. KI er ikke brukt til å erstatte mitt eget arbeid. KI har kun blitt brukt til å komme med eksempler og rette opp noen deler av språket.

2. Bilder og figurer

Jeg har ikke brukt KI til å generere bilder, figurer eller diagrammer i rapporten.

Jeg erklærer at all bruk av KI-verktøy eller ressurser er tydelig oppgitt enten i rapporten eller i dette erklæringsskjemaet.

Navn / Dato:

Mark Tzvetoslavov Dochev / 29.04.2026

Del 1- Innledning

Følgende rapport prøver å ta for seg en helhetlig vurdering av nettverkssikkerheten i et mellomstort norsk konsulentselskap med rundt 20 ansatte. Selskapet har nylig gått over fra et tradisjonelt kontorarbeid til en mer hybrid arbeidshverdag. Her har de fleste ansatte både hjemmekontor og vanlig kontorarbeid. Dette har ført til at selskapet har blitt mer avhengig av å bruke VPN, skytjenester, e-post og ikke minst en ekstern tilgang til interne systemer.

IT-teamet har lagt merke til at flere mistenkelige hendelser har skjedd. Noen ansatte har fått for eksempel fått flere phishing-eposter som «ser ut» til å komme fra ledelsen. Det har også vært mange mislykkede innloggingsforsøk på VPN-tjenesten fra utenlandske IP-adresser. Det har også blitt oppdaget mistenkelig DNS-trafikk fra en arbeidsstasjon i økonomiavdelingen. Det er også verdt å nevne at en ansatt har rapportert dårligere systemytelse etter å ha åpnet et e-postvedlegg.

Vi kan tenke oss at hvert av disse hendelsene kan være tilfeldig i seg selv. Men når alle disse foregår nesten samtidig, kan dette tyde på at noe er feil og at handler om et cyber angrep. Formålet med denne rapporten er å identifisere alle trusler, analysere arkitekturen til bedriften og komme med ulike sikkerhetstiltak som bedriften kan anvende for å håndtere disse innen de første 24 timer.

1.Trusselidentifisering og angrepsvektorer

Etter å ha analysert case-beskrivelsene og gått gjennom de ulike truslene nevnt, kan vi konkludere at det er snakk om følgende trusler:

- Phising
- Brute-Force
- Skadevare på klient maskiner
- Command-and-Control-kommunikasjon.

Disse kan behandles separat, men i mening, bør disse ikke behandles separate da de kan henge sammen. La oss se nærmere på hvert av dem og begrunne hvorfor disse kan behandles som en helhetlig trussel.

Phishing

Flere ansatte har fått ulike e-poster som hevder å ha blitt sendt fra ledelsen. E-postene ber mottakeren åpne et vedlegg og bekrefte sensitiv informasjon. Dette er ganske alvorlig da angriperen utnytter tilliten arbeideren har mot «ledelsen». Dette kan ses som et slags **sosial manipulering**, da dette fører til at ansatte gjør ting som de ellers ikke de ville gjort (som for eksempel laste ned filer, trykke på ukjente lenker, åpne vedlegg, osv.)

Det er flere formål med Phishing. Første jeg kan tenke meg er at angriperen på den ene siden prøver å stjele data som brukernavn og passord for å kunne få tilgang til sensitiv data (alt fra kontrakter, journaler, økonomiske dokumenter, osv.). I vårt tilfelle har en ansatt rapport om treigere internettforbindelse og treig maskin etter å ha åpnet et e-postvedlegg. Dette tyder på at en skadevare kan ha blitt installert etter phishing e-posten ble åpnet.

Brute-Force (Credential stuffing)

IT-teamet har oppdaget en del mislykkede påloggingsforsøk mot VPN. Dette skjedde utenfor vanlig arbeidstid, både om natten og i helgene. Det er oppdaget at forsøkene kommer fra IP-adresser som er utenfor Norge. Dette er et ganske tydelig tegn på at det ikke er ansatte som har for eksempel skrevet feil passord. Dette skjer ved hjelp av automatiserte programmer som gjetter seg frem med ulike passord fra passord som er vanlige eller som har blitt lekket (enten via cyber eller phishing angrep).

Grunnen til at VPN er så attraktivt for angriperne er fordi disse gir tilgang til interne ressurser. Hvis en angriper klarer for eksempel å logge seg inn via VPN, vil systemet ikke detektere noe feil og vil se disse som «legitime brukere». Da kan disse angriperne få tilgang til for eksempel:

- Filservere
- interne applikasjoner
- HR-systemer / økonomisystemer.

Skadevare

En ansatt har rapport om dårligere systemytelse etter å ha åpnet et e-postvedlegg. Det kan være ulike årsaker til dette, men når vi har allerede vært innom phishing og at IT-teamet har oppdaget mistenkelig nettverkstrafikk, så kan det være stor sannsynlighet på at det er snakk om et skadelig vare. Denne kan brukes til følgende:

- stjele viktig informasjon
- logge tastetrykk
- åpne bakdører til allerede eksisterende programmer
- kryptere filer
- gi angriperen fjernkontroll over maskinen.

Kommunikasjon

IT-teamet har også oppdaget ganske uvanlig og mistenkelig trafikk fra en arbeidsstasjon i økonomiavdelingen sent på natten. Det har i tillegg blitt fanget DNS-forespørsler til ukjente domener. Dette i prinsippet betyr at en infisert maskin, som angriperen har allerede tilgang til, prøver å kontakte en server som er kontrollert av selve angriperen. Denne type kommunikasjon brukes til følgende aktiviteter:

- sende status mellom hverandre
- motta kommandoer
- laste ned andre type skadevare som kan gi enda høyere privilegier

Det er viktig å nevne at her angriperen valgt en veldig viktig gren i selskapet, nemlig økonomi avdelingen. Denne har oftest mest tilgang til sensitivt data som for eksempel:

- lønn
- personlig info til arbeiderne
- fakturaer
- kunde informasjon
- betalingsinformasjon
- interne økonomi systemer

Hvordan henger disse punktene sammen?

Her er en min teori om sammenhengen mellom hendelsene som har skjedd i bedriften:

1. Angriperen sendte ulike phishing-eposter til ansatte.
2. En eller flere ansatte har åpnet det vedlegget sendt gjennom e-posten.
3. Vedlegget installerte skadevaren som muligens har gitt angriperen tilgang til det eksterne systemet.
4. Den infiserte maskinen som skadevaren ble installert på begynte å sende DNS-forespørsler, og prøvde å kontakte eksterne domener.
5. Angriperen forsøkte å få VPN-tilgang ved brute-force.
6. Dersom VPN-tilgang ble oppnådd, kunne angriperen ha beveget seg videre internt i bedriftens nettverk.

2.2 Nettverksarkitektur og segmentering

Nettverksarkitekturen i selskapet kan deles i fler viktige deler. Her er en liste over de:

- Lokalt kontornett / Gjestenett
- VPN (Virtual Private Network)
- Skytjenester
- E-post / Nettside
- Interne administrative systemer.

For at vi skal kunne jobbe videre med rapporten og komme med en løsning, kan vi første analysere disse og finne ut hvordan disse henger sammen.

Vi startet første med «det lokalet kontornett» eller med andre ord «LAN». Denne innebærer alle ansattes arbeidsstasjoner, interne servere og systemer. Vi kan med andre ord si at dette er selve kjernen i selskapet. Her kan vi finne alt fra filservere til internere applikasjoner som er nødvendig for den daglige driften av selskapet og når noen eksterne får tilgang til denne, kan de lett bevege seg mot andre interne systemer som ellers hadde vært vanskelig å treige seg igjennom.

Hvis vi går videre til gjestenettet, har denne som formål å bli anvendt av besøkende eller eksterne samarbeidspartnere. Selv om den er isolert fra det interne nettverket, er det viktig at den kontrolleres og overvåkes. Dette er fordi dersom den gir tilgang til interne servere eller klienter for eksempel, så kan det være en utfordring i seg selv og kan føre til uønskede hendelser.

I den forbindelsen, kan vi også nevne noe som er veldig relevant for selskapet, og det er nemlig bruken av VPN. Denne brukes av ansatte for å nå interne resurser når de ikke befinner seg på kontoret. Dette er ganske praktisk og hjelpsomt. Men det er verdt å nevne at VPN-tilgangen burde begrenses etter rolle og behov siden denne kan bli kompromittert og kan gi angriperen samme tilgang som selve ansatte som bruker denne.

Hvis vi går videre til skytjenester, er Microsoft-løsningene noe vi burde nevne. De fleste Microsoft løsninger brukes for dokument deling og samarbeid. Vi er kjent med de fleste av dem, som for eksempel:

- Microsoft 365
- Teams
- OneDrive / SharePoint

Problemet med disse er at de er brukt over hele verden og er den løsningen nesten alle bedrifter går for. Det som gjør dem attraktive for angripere er at dersom de får tilgang til en bruker konto, kan de faktisk få tilgang til ganske mye viktig informasjon som for eksempel:

- Lese sendte/mottatt e-poster
- Lasting av dokumenter
- Sende phishing e-poster internt
- Innsikt i viktig og sensitiv informasjon

Derfor er e-post systemet en av de mest utsatt tjenestene i bedriften, da denne er «hovedkanalen» for phishing. Selv om vi tenker at dette ikke har så stor innvirkning, kan denne føre til ganske mye skade. Derfor er det viktig at selskapet har riktig opplæring, har en form for autentisering og gode filtre for å skylde mellom dem.

I vårt tilfelle, er HR- og økonomisystemene de mest sensitive systemene. De inneholder følgende:

- Personaldata
- Lønnsdata
- økonomisk informasjon
- annen sensitiv informasjon.

I min mening, burde slike systemer være i egne sikkerhetssoner, ikke i samme nettverk som vanlige arbeidsstasjoner. Tillitsgrensene i nettverket MÅ være tydelige. Disse skiller mellom ulike områder med forskjellige sikkerhetsnivåer. Her er et eksempel på hvordan de kan se ut:

LAN	Høyt	Internt nett med ansatte og servere
Gjestenett	Lavt	Skal kun ha internett, ikke intern tilgang
VPN	Middels/høyt	Ekstern tilgang, men bør begrenses
Skytjenester	Middels	Avhengig av konto- og tilgangsstyring

Offentlig nettside	Lavt	Eksponert mot internett
HR/økonomi	Svært høyt	Inneholder sensitive data

Svakheter

Første svakhet som jeg kan tenke meg kan være et problem er at LAN kan være for flatt. Med andre ord betyr dette at de fleste henter kan kommunisere «direkte» med hverandre. Dette kan være en utfordring siden det kan føre til at en angriper kan komme seg videre til servere eller andre klienter dersom en vanlig arbeidsstasjon blir kompromittert. Andre svakheten kan være at VPN-brukere får bred tilgang, uten at tilgangen begrenses. Et godt eksempel kan være hvis en vanlig it-arbeider eller konsulent har samme rettigheter som HR-ansvarlig. Verdt å nevne at en stor svakhet som ikke bør oversees at arbeidsstasjonen på økonomi avdelingen kommuniserer med ulike ukjente domener på natt. Dette burde ikke overses.

Forbedringer

Her er det en liste over ting som kan forbedres i selskapet:

VLAN for ulike avdelinger	Skiller økonomi, HR, klienter og servere
Eget servernett	Servere bør ikke ligge i samme sone som vanlige klienter
Eget sikkerhetsområde for HR/økonomi	Sensitive systemer får ekstra beskyttelse
Strengere VPN-tilgang	Brukere får kun tilgang til det de trenger
Zero Trust-prinsipp	Ingen bruker eller enhet stoles automatisk på
Brannmur mellom soner	Trafikk mellom soner må godkjennes

DNS-filtrering	Blokkerer mistenkelige og ondsinnede domener
Nettverksovervåking	Oppdager uvanlige trafikkmønstre

2.3 Hendelsesanalyse og prioritering

Det er veldig viktig å prioritere hendelsene etter viktighet når de først skjer samtidig. Det handler hovedsakelig å kunne kategorisere de etter hvor stor risiko de utgjør og hvilke konsekvenser de kan få. Når det er flere hendelser som skjer samtidig, bør man kunne prioritere disse etter hvor sannsynlig det er at de fører til skade, kompromittering og omdømme.

1. Mistenkelig DNS-trafikk fra økonomiavdelingens arbeidsstasjon
 - a. Kan tyde på aktiv kompromittering og C2-kommunikasjon
2. Ansatt åpnet e-postvedlegg og fikk treg maskin
 - a. Kan være skadevareinfeksjon
3. Mislykkede VPN-pålogginger fra utenlandske IP-adresser
 - a. Kan føre til uautorisert tilgang
4. Phishing-eposter som ser ut som de kommer fra ledelsen
 - a. Kan lure flere ansatte og spre angrepet
5. Risiko mot sky og offentlig nettside
 - a. Viktig, men mindre akutt enn mulig aktiv kompromittering

Den mest alvorlige hendelsen er den mistenkelige DNS-trafikken som kommer fra økonomiavdelingen. Dette kan bety at en maskin allerede er kompromittert. Samtidig har en ansatt åpnet et vedlegg og opplevd at maskinen ble tregere, noe som kan tyde også på skadevare. Dette er ganske normalt siden det skjer nesten samtidig som phishing-eposten ble åpnet. VPN-angrepene er også ganske alvorlige da en angriper kan få tilgang til interne systemer dersom passord blir gjettet eller stjålet, særlig hvis det ikke brukes tofaktorautentisering. I min mening burde phishing-epostene tas på alvor og selskapet bør

finne ut hvem som har mottatt dem og om flere har åpnet vedlegg. Her legger jeg ved en mulig angrepstidslinje:

1. Angriperen kartlegger selskapet og finner ansatte, ledere eller e-postadresser.
2. Angriperen lager phishing-eposter som ser ut som de kommer fra ledelsen.
3. E-postene sendes til ansatte og ber dem åpne vedlegg eller bekrefte sensitiv informasjon.
4. En eller flere ansatte åpner vedlegget.
5. Skadevare installeres på minst én arbeidsstasjon.
6. Den infiserte maskinen begynner å kontakte ukjente domener via DNS.
7. Angriperen bruker skadevaren til å etablere en command-and-control-forbindelse.
8. Samtidig forsøker angriperen VPN-brute force for å få stabil tilgang.
9. Hvis angriperen lykkes, kan neste steg være en lateral bevegelse mot filservere, HR-systemer eller økonomisystemer.
10. Til slutt kan angriperen forsøke å hente ut data, stjele passord eller spre seg videre.

Redusering av risiko

I følgende avsnitt kan vi se litt på hvordan selskapet kan innføre midlertidig og varige tiltak for å redusere risikoen. Først og fremst, før vi kan sette oss inn i vanskeligere og kompliserte tiltak, kan vi finne frem den antatte «skadet» arbeidsstasjonen og koble den fra nettverket. Her er det viktig at vi ikke sletter noe data eller formaterer den, da vi kan anvende den for å hende nødvendig informasjon som kan brukes som bevis dersom dette er nødvendig. Det vi gjør i istedenfor er å koble den av fra både LAN og WIFI.

Tiltak nummer to som kan anvendes i vårt tilfelle er å oppdatere alle brannmurreglene for å blokkere alt av mistenkelig domener og IP-adresser. I prinsippet innebærer dette å begrense alt av trafikk fra klientmaskinene (gjelder ukjente porter). Å sette opp en egen DNS-løsning også kan være et bra alternativt.

Som et tredje tiltak kan nettverkssegmentering vurderes. Denne kan redusere risikoen dramatisk da en hvilken som helst arbeidsstasjon, som oftest en som allerede er kompromittert, ikke får direkte tilgang til sensitive systemer. Med denne nevnt, er det viktig å påpeke at økonomiavdelingen bør ha sin egen sone. Dette vil da også medføre at økonomi systemer og alt annet relatert (HR for eksempel) skal kun være tilgjengelig for utvalgte brukere/enheter.

Sist, men ikke minst, kan tilgangskontroll også vurderes. Brukere skal kun få de rettighetene de trenger. Ikke mer og ikke mindre. Dette er fordi hvis en vanlig bruker blir kompromittert, vil ikke angriperen få tilgang til sensitiv data gjennom å komme seg til viktige interne systemer.

2.4 Sikkerhetstiltak

Selskapet skal kunne ta i bruk både tekniske og organisatoriske tiltak for å øke sikkerheten. Det er viktig å nevne at disse tiltakene skal kunne tilpasses etter de konkrete truslene som blir presentert.

MFA

I min mening, første og viktigste tiltak som selskapet kan innføre er flerfaktorautentisering (MFA). MFA skal brukes alle mulige tjenester, som for eksempel:

- VPN
- Microsoft 365
- e-post
- administrative kontoer
- andre viktige systemer.

Grunnen til dette er fordi det holder ikke med bare passord for å kunne logge seg inn. Dette er fordi dersom en angriper tar for eksempel tak i passordet ditt og kontoen din er beskyttet med MFA, vil denne hindre angriperen med å logge seg inn.

E-post sikkerhet

Tiltak nummer 2 som kan anvendes er å forbedre selskapet e-post sikkerhet. Selskapet skal kunne anvende e-postfiltre som stopper phishing forsøk. Dette innebærer også skadelig skadevare, lenker, osv. Vitkig også å sette opp SPF, DKIM og DMARC. Disse er tre e-post autentiseringsmetoder som vil da redusere risikoen for an en ekstern person (angriper) sender e-post som utgir seg til å være fra ledelsen eller som kommer fra selskapets domene.

EDR

Tredje tiltaket som kan anvendes av selskapet er å bruke Endpoint Detection and Response (EDR). EDR skal installeres på alle arbeidsstasjoner og servere. EDR gjør det mulig:

- å oppdage mistenkelige prosesser
- ukjente programmer
- unormal nettverkstrafikk
- forsøk på å endre systemfiler.

I vårt tilfelle kan denne tiltak gjøre det lettere for å undersøke hvordan økonomiavdelingens PC ble infisert.

DNS-filtrering

Fjerne tiltak som kan anvendes av selskapet er å innføre DNS-filtrering. Case-beskrivelsen nevner DNS-forespørsler til ukjente domener. Derfor kan DNS-filtrering blokkere tilgang til kjente farlige domener og gir bedre oversikt over hvilke maskiner som prøver å kontakte mistenkelige adresser.

Segmentering av nettverket

Femte tiltak som kan anvendes av selskapet er å segmentere nettverket. Selskapet bør dele opp nettverket i ulike soner som:

- klientnett
- servernett
- økonominett
- HR-sone
- Gjestenett

I tillegg skal disse kunne inneholde brannmurregler mellom sonene som styrer hvilken trafikk som er tillatt. Da kan ikke en angriper bevege seg fritt hvis én maskin blir kompromittert.

Tilgangskontroll

Sjette tiltak som kan anvendes av selskapet er å stramme inn tilgangskontrollen. Ansatte skal bare ha tilgang til systemene de trenger i jobben. Derfor skal administrative rettigheter begrenses mest mulig. Et eksempel kan være at lokale administratorrettigheter på vanlige PC-er skal fjernes hvis det ikke er nødvendig.

IDS / IPS

IDS (Intrusion Detection System) og IPS (Intrusion Prevention System) kan også være nyttige sikkerhetstiltak som kan anvendes av selskapet. IDS vil da overvåke nettverkstrafikk og varsler IT-teamet ved mistenkelig aktivitet, mens IPS kan oppdage og blokkere slik trafikk automatisk. Forskjellen er derfor at IDS bare varsler, mens IPS også kan stoppe angrep. Det er viktig å nevne at IDS krever oppfølging og IPS kan skape problemer hvis det faktisk blokkerer legitim trafikk. Siden selskapet har få IT-ressurser, kan det være lurt å bruke en administrert sikkerhetstjeneste som kombinerer IDS/IPS, EDR og SIEM.

Opplæring

Siste mulig tiltak som kan anvendes av selskapet er å gi de ansatte sikkerhetsopplæring.

Her skal de ansatte læres å gjenkjenne mistenkelig e-poster, lenker, vedlegg, språk, falske avsendere, osv. I tillegg skal ansattes læres hvordan disse kan rapporteres.

Jeg har laget en tabell med en oversikt over de ulike sikkerhetstiltakene:

Phishing	Opplæring, e-postfilter, SPF/DKIM/DMARC	Reduserer risikoen for at ansatte blir lurt
VPN-angrep	MFA, konto-lockout, geoblokking, logging	Stopper innlogging med stjålne eller gjettete passord
Skadevare	EDR, antivirus, patching	Oppdager og stopper ondsinnet aktivitet
C2-kommunikasjon	DNS-filtrering, brannmur, IDS/IPS	Blokkerer kontakt med angriperens infrastruktur
Lateral bevegelse	VLAN, segmentering, tilgangskontroll	Hindrer angriperen i å bevege seg fritt
Manglende oversikt	SIEM og sentral logging	Gjør det lettere å oppdage sammenhenger

2.5 Overvåking, deteksjon og hendelseshåndtering

De første 24 timer etter en hendelse har skjedd er avgjørende. Målet er å finne om selskapet har faktisk blitt kompromittert. Etter dette de viktigste stegene er å stoppe skaden som har blitt gjort og samle så mye bevis som mulig for videre analyse. Derfor er det viktig at IT-teamet prioriterer logger som kan vise hva som har skjedd, hvilke komponenter (systemer, enheter) har blitt kompromittert og om personen/e som har utført skaden fortsatt har tilgang.

Her er det en liste med de viktigste loggene selskapet burde se etter:

- **VPN-logger**
 - VPN-logger er viktige da de kan vise:
 - hvem som har prøvd å logge seg inn
 - når en hendelse skjedde
 - fra hvilke IP-adresser ble det prøvd
 - var noen av de forsøke vellykkede?
 - IT-teamet bør se etter:
 - innlogginger fra uvanlige land
 - tidspunkter
 - IP-adresser med mange feilede forsøk.
- **DNS-logger**
 - DNS-logger er viktige fordi det allerede er oppdaget trafikk mot ukjente domener. IT-teamet bør derfor sjekke:
 - hvilke domener økonomimaskinen har blitt kontaktet
 - hvor ofte det skjer
 - gjør andre maskiner det samme?
 - Hvis flere maskiner kontakter samme mistenkelige domene, kan dette tyde på at det har vært en spredning.
- **E-postlogger**
 - E-postlogger vil da hjelpe IT-teamet med å finne ut hvem som har mottatt phishing-e-postene, om noen har klikket på noen av lenkene eller om noen har åpnet vedlegget fra e-posten.
 - De bør også sjekke om avsenderen er forfalsket og om noen av e-postene ble sendt til flere ansatte samtidig.
- **Endepunktlogger**
 - Endepunktlogger er viktige for å undersøke hvilke maskiner som er berørte.
 - IT-teamet bør se etter:
 - nye prosesser

- ukjente programmer
- endringer i oppstartfiler
- mistenkelige tilkoblinger
- uvanlig ressursbruk.
- Brannmurlogger
 - Brannmurlogger vil da vise trafikk inn og ut av nettverket.
 - Disse kan brukes til å finne ut om det har vært kontakt med:
 - mistenkelige IP-adresser
 - uvanlige porter
 - land selskapet normalt ikke kommuniserer med.
 - Loggene kan da også bekrefte om blokkeringstiltak fungerer.
- Microsoft 365-logger.
 - Disse logger er viktige fordi selskapet bruker Microsofts skytjenester.
 - IT-teamet bør se etter:
 - mistenkelige innlogginger
 - nye innboksregler
 - uvanlig fildeling
 - store nedlastinger
 - tilgang fra ukjente steder.

Her er det et prioritert loggoversikt som selskapet kan anvende:

VPN-logger	Mislykkede og vellykkede innlogginger, land, IP-adresser, tidspunkt
DNS-logger	Ukjente domener, gjentatte forespørsler, C2-mønstre
E-postlogger	Mottakere av phishing, vedlegg, lenker, klikk
Endepunktlogger	Ukjente prosesser, skadevaretegn, utgående trafikk

Brannmurlogger	Uvanlige porter, IP-adresser, store datamengder
Microsoft 365-logger	Mistenkelige innlogginger, fildeling, kontoaktivitet

Umiddelbare tiltak

Her er det en liste over umiddelbare tiltak de første 24 timer etter et angrep:

1. Isolere økonomiavdelingens mistenkelige arbeidsstasjon fra nettverket.
2. Isolere maskinen for den ansatte som åpnet vedlegget.
3. Ikke slette eller formatere maskinene før bevis er samlet.
4. Samle inn relevante logger.
5. Tilbakestille passord for berørte brukere.
6. Aktivere eller kontrollere MFA på VPN og Microsoft-kontoer.
7. Blokkere mistenkelige domener og IP-adresser.
8. Søke etter de samme indikatorene på andre maskiner.
9. Informere ansatte om phishing-kampanjen.
10. Varsle ledelsen og vurdere behovet for ekstern sikkerhetshjelp.

Som et siste del av innlevering, vil jeg gjerne snakke litt om inneslutning. Dette handler hovedsakelig om å hindre at skaden sprer seg, for eksempel ved å isolere mistenkelige maskiner og blokkere skadelig trafikk. Dette vil da føre til at skadevaren som ble påvirket eller årsaken til hendelsen fjernes. Til slutt vil det gjenopprettes normal drift på en trygg måte.

Et SIEM-system kan hjelpe ved å samle logger fra VPN, brannmur, DNS og Microsoft 365 på ett sted. Det gir selskapet en bedre oversikt og kan varsle når flere mistenkelige hendelser skjer samtidig.

Roller

Rolle inndeling er veldig viktig i den delen av rapporten. Her har jeg laget en tabell med rolleinndeling, ut ifra antall ansatt og deres rolle. Disse skal være klart og tydelig.

Siden selskapet nevner at de kun har to IT-ansatte, er det viktig å holde responsen enkel.

De bør først fokusere på de mest kritiske systemene:

1. økonomimaskinen
2. VPN
3. E-post
4. DNS.

Hvis analysen viser tegn på at det har vært datalekkasje eller at andre viktig data har blitt kompromittert, bør selskapet vurdere ekstern hjelp (fra andre IT-selskaper) eller eventuelle juridiske krav knyttet til personopplysninger.

IT-ansatt 1	Teknisk analyse av klientmaskiner og logger
IT-ansatt 2	VPN, brannmur, DNS-blokkering og tilgangskontroll
Ledelsen	Beslutninger, prioritering og eventuell varsling
Ansatte	Rapportere phishing og uvanlig systemoppførsel
Ekstern sikkerhetspartner	Bistå ved alvorlig hendelse eller manglende kapasitet

Del 2 - Teknisk undersøkelsesmetode: Pakkeanalyse med Wire Shark

Jeg har valgt Wireshark fordi caset nevnte flere mistenkelig utgående trafikk og DNS-forespørsler fra en arbeidsstasjon i økonomiavdelingen. Wireshark er et verktøy som kan brukes til å undersøke:

- hvilke domener
- IP-adresser
- porter og
- protokoller maskinen kommuniserer med.

Målet vårt trenger nødvendigvis ikke å være å lese innholdet i trafikken, men å finne ulike mønstre som kan vise oss tegn på kompromittering, da mye av trafikken er kryptert. Det første jeg hadde gjort i dette tilfelle er å se på selve DNS-trafikken. Grunnen til dette er fordi skadevare ofte bruker DNS for å kontakte command-and-control-servere. Noen tegn som vi kan anvende som kan gi hjelpe oss å identifisere kompromittering er:

- mange oppslag til ukjente domener
- domener med tilfeldige tegn
- gjentatte forespørsler til samme sted.

Neste steg jeg hadde tatt var å undersøke nærmere utgående:

- TCP-trafikk
- HTTP-trafikk
- HTTPS-trafikk.

Her kan vi faktisk se hvilke eksterne IP-adresser den kompromitterte maskinen kontakter, hvilke porter som anvendes og tidspunkt (i tillegg til ulike type data). Noen som kan tyde på **beaconing** er regelmessige tilkoblinger til samme ukjente IP. Med andre ord vil den

kompromitterte maskinen sender signaler til angriperen. I tillegg vil store mengder utgående data også være tegn på datalekkasje.

I tillegg til alt nevnt ovenfor, hadde jeg også lettet etter uvanlige porter. Vanlig nettlesertrafikk går ofte over port 80 og 443, så trafikk på andre porter som ikke er disse, bør analyseres og undersøkt I tillegg til dette kan angriperen bruke vanlige porter for å skjule seg.

Her kommer det en liste med eksempler på relevante Wireshark-filtre:

- `dns` – viser DNS-trafikk og domener maskinen spør etter.
- `tcp` – viser TCP-trafikk.
- `http` – viser ukryptert webtrafikk.
- `tls` – viser HTTPS/TLS-trafikk og metadata.
- `udp` – viser UDP-trafikk.
- `icmp` – viser ping/ICMP-trafikk.
- `ip.addr == [IP-til-maskin]` – viser all trafikk til og fra maskinen.
- `ip.src == [IP-til-maskin]` – viser trafikk ut fra maskinen.
- `ip.dst == [IP-adresse]` – viser trafikk til en bestemt IP.
- `tcp.port == 443` – viser HTTPS-trafikk.
- `tcp.port == 80` – viser HTTP-trafikk.
- `tcp.port != 80 and tcp.port != 443` – viser trafikk utenom vanlige webporter.

(filtre hentet fra ChatGPT)

For denne case-beskrivelse, hadde jeg valgt å starte med å se på trafikken fra økonomiavdelingens arbeidsstasjon og sammenligne funnene med DNS-logger og brannmurlogger. Dette betyr at hvis både Wireshark og loggene viser kontakt med samme ukjente domene, vil dette føre til at vi har enda mer bevis som styrker mistanken om at maskinen har blitt kompromittert.

Begrensninger

Det er viktig å nevne at Wireshark har også en del begrensninger. Her er den liste med de vanligste begrensninger:

- Mye trafikk som går gjennom, er kryptert
- Opptaket kan mangle historiske data
- ukjent trafikk betyr ikke automatisk at noe er ondsinnet.

Dette vil med andre ord si at vi burde anvende Wireshark sammen med DNS-logger, brannmurlogger, EDR og SIEM. På den måten vil IT-teamet få et bedre grunnlag for å vurdere om trafikken skyldes skadevare eller normal aktivitet.

Kilder

Alt data har blitt hentet fra forelesning slidene og videoene publisert på moodle. Alt innholdet er skrevet på egen hånd.